



Light ☐ Dark

Security ▾

Discover what's coming to Microsoft Ignite, Nov 17-20, 2026. [Register now.](#)

[Blog home](#) > How Microsoft discovers and mitigates evolving attacks against AI guardrails

Search the blog



[Research](#) • April 11, 2024 • 7 min read

How Microsoft discovers and mitigates evolving attacks against AI guardrails

By [Mark Russinovich](#), Chief Technology Officer, Microsoft Azure

SHARE



THREATS INTELLIGENCE CONTENT TYPES

AI threats

Research

TOPICS

AI and agents

Security operations

Threat intelligence

Show more ▾

As we continue to integrate generative AI into our daily lives, it's important to understand the potential harms that can arise from its use. Our [ongoing commitment](#) to advance safe, secure, and trustworthy AI includes transparency about the capabilities and limitations of large language models (LLMs). We prioritize research on societal risks and building secure, safe AI, and focus on developing and deploying AI systems for the public good. You can read more about Microsoft's approach to securing generative AI with [new tools we recently announced](#) as available or coming soon to Microsoft Azure AI Studio for generative AI app developers.

We also made a commitment to identify and mitigate risks and share information on novel, potential threats. For example, earlier this year Microsoft shared the principles shaping [Microsoft's policy and actions](#) blocking the nation-state advanced persistent threats (APTs), advanced persistent manipulators (APMs), and cybercriminal syndicates we track from using our AI tools and APIs.

In this blog post, we will discuss some of the key issues surrounding AI harms and vulnerabilities, and the steps we are taking to address the risk.

The potential for malicious manipulation of LLMs

One of the main concerns with AI is its potential misuse for malicious purposes. To prevent this, AI systems at Microsoft are built with several layers of defenses throughout their architecture. One purpose of these defenses is to

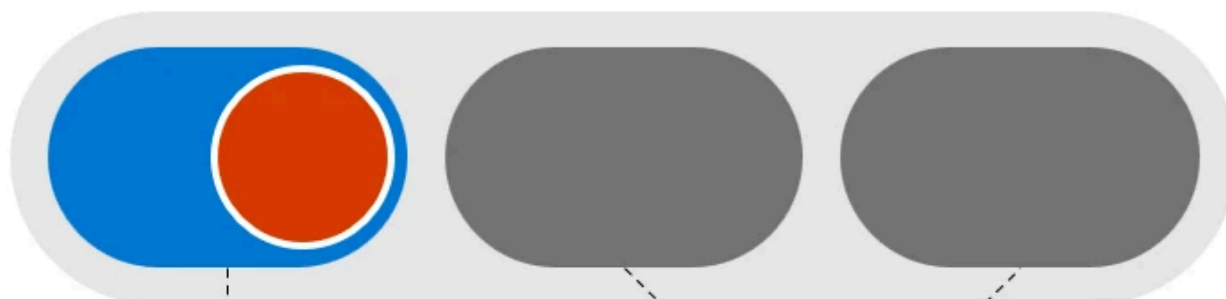
limit what the LLM will do, to align with the developers' human values and goals. But sometimes bad actors attempt to bypass these safeguards with the intent to achieve unauthorized actions, which may result in what is known as a "jailbreak." The consequences can range from the unapproved but less harmful—like getting the AI interface to talk like a pirate—to the very serious, such as inducing AI to provide detailed instructions on how to achieve illegal activities. As a result, a good deal of effort goes into shoring up these jailbreak defenses to protect AI-integrated applications from these behaviors.

While AI-integrated applications can be attacked like traditional software (with methods like buffer overflows and cross-site scripting), they can also be vulnerable to more specialized attacks that exploit their unique characteristics, including the manipulation or injection of malicious instructions by talking to the AI model through the user prompt. We can break these risks into two groups of attack techniques:

- **Malicious prompts:** When the user input attempts to circumvent safety systems in order to achieve a dangerous goal. Also referred to as user/direct prompt injection attack, or UPIA.
- **Poisoned content:** When a well-intentioned user asks the AI system to process a seemingly harmless document (such as summarizing an email) that contains content created by a malicious third party with the purpose of exploiting a flaw in the AI system. Also known as cross/indirect prompt injection attack, or XPIA.

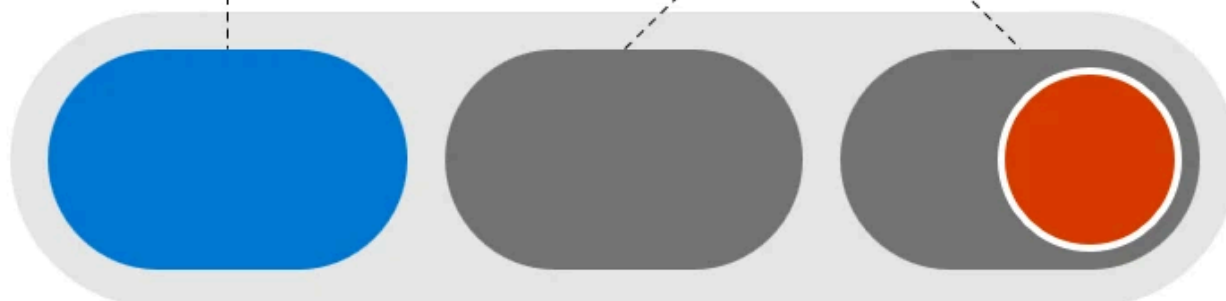
Malicious prompt

Prompt contains malicious instructions (single or multi-step)



User prompt

Content for analysis



Poisoned content

Document contains malicious instructions

Today we'll share two of our team's advances in this field: the discovery of a powerful technique to neutralize poisoned content, and the discovery of a novel family of malicious prompt attacks, and how to defend against them with multiple layers of mitigations.

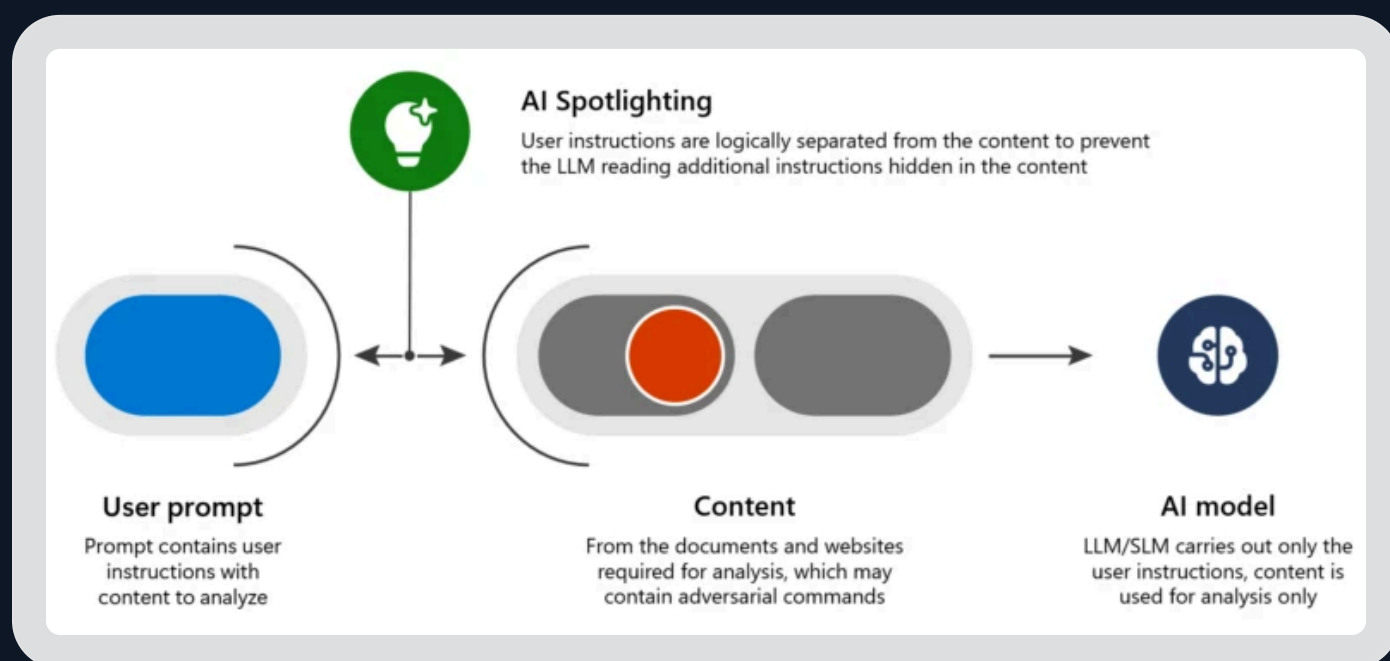
Neutralizing poisoned content (Spotlighting)

Prompt injection attacks through poisoned content are a major security risk because an attacker who does this can potentially issue commands to the AI

system as if they were the user. For example, a malicious email could contain a payload that, when summarized, would cause the system to search the user's email (using the user's credentials) for other emails with sensitive subjects—say, "Password Reset"—and exfiltrate the contents of those emails to the attacker by fetching an image from an attacker-controlled URL. As such capabilities are of obvious interest to a wide range of adversaries, defending against them is a key requirement for the safe and secure operation of any AI service.

Our experts have developed a family of techniques called Spotlighting that reduces the success rate of these attacks from more than 20% to below the threshold of detection, with minimal effect on the AI's overall performance:

- **Spotlighting** (also known as data marking) to make the external data clearly separable from instructions by the LLM, with different marking methods offering a range of quality and robustness tradeoffs that depend on the model in use.



Mitigating the risk of multiturn threats (Crescendo)

Our researchers discovered a novel generalization of jailbreak attacks, which we call **Crescendo**. This attack can best be described as a **multiturn LLM**

jailbreak, and we have found that it can achieve a wide range of malicious goals against the most well-known LLMs used today. Crescendo can also bypass many of the existing content safety filters, if not appropriately addressed. Once we discovered this jailbreak technique, we quickly shared our technical findings with other AI vendors so they could determine whether they were affected and take actions they deem appropriate. The vendors we contacted are aware of the potential impact of Crescendo attacks and focused on protecting their respective platforms, according to their own AI implementations and safeguards.

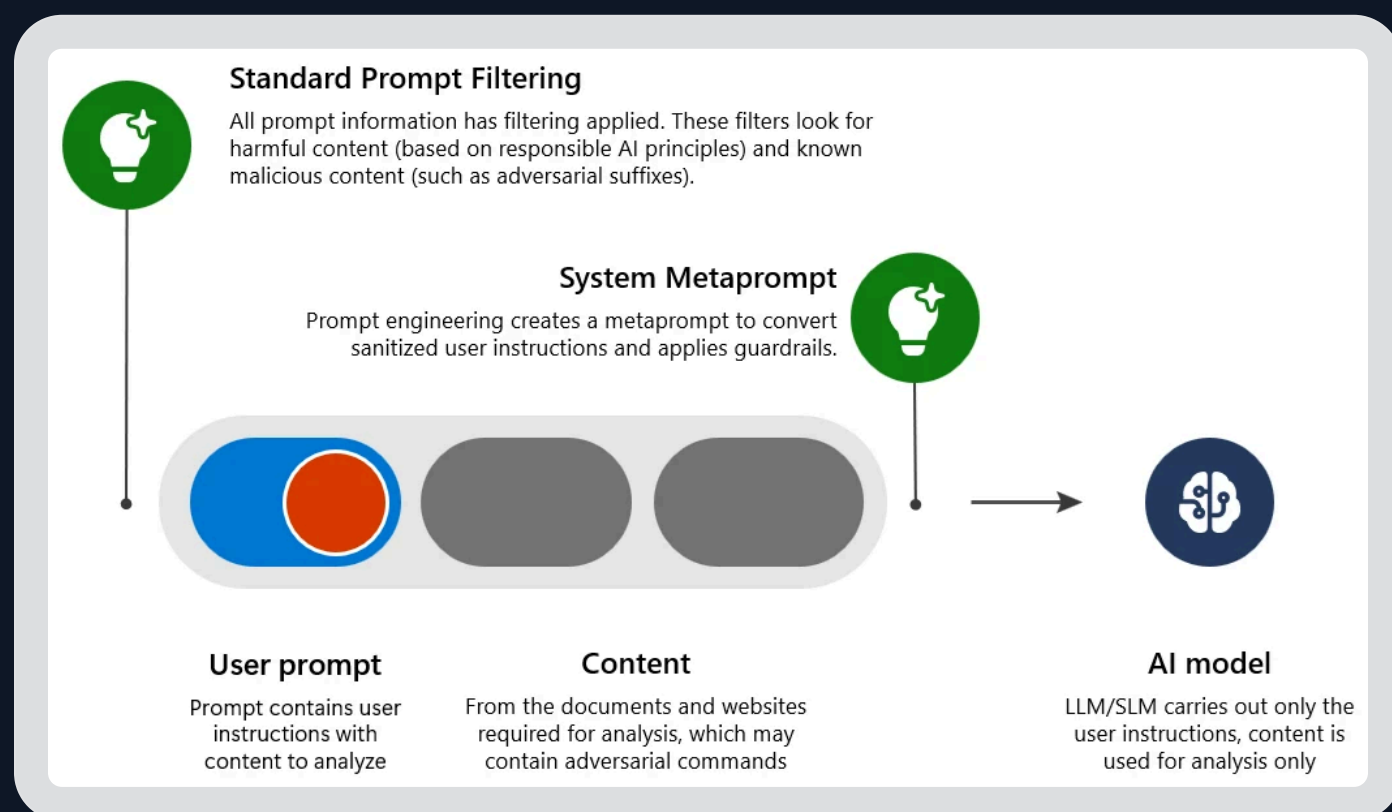
At its core, Crescendo tricks LLMs into generating malicious content by exploiting their own responses. By asking carefully crafted questions or prompts that gradually lead the LLM to a desired outcome, rather than asking for the goal all at once, it is possible to bypass guardrails and filters—this can usually be achieved in fewer than 10 interaction turns. You can read about Crescendo's results across a variety of LLMs and chat services, and more about how and why it works, in our [research paper](#).

While Crescendo attacks were a surprising discovery, it is important to note that these attacks did not directly pose a threat to the privacy of users otherwise interacting with the Crescendo-targeted AI system, or the security of the AI system, itself. Rather, what Crescendo attacks bypass and defeat is content filtering regulating the LLM, helping to prevent an AI interface from behaving in undesirable ways. We are committed to continuously researching and addressing these, and other types of attacks, to help maintain the secure operation and performance of AI systems for all.

In the case of Crescendo, our teams made software updates to the LLM technology behind Microsoft's AI offerings, including our Copilot AI assistants, to mitigate the impact of this multiturn AI guardrail bypass. It is important to note that as more researchers inside and outside Microsoft inevitably focus on finding and publicizing AI bypass techniques, Microsoft will continue taking action to update protections in our products, as major contributors to AI security research, bug bounties and collaboration.

To understand how we addressed the issue, let us first review how we mitigate a standard malicious prompt attack (single step, also known as a one-shot jailbreak):

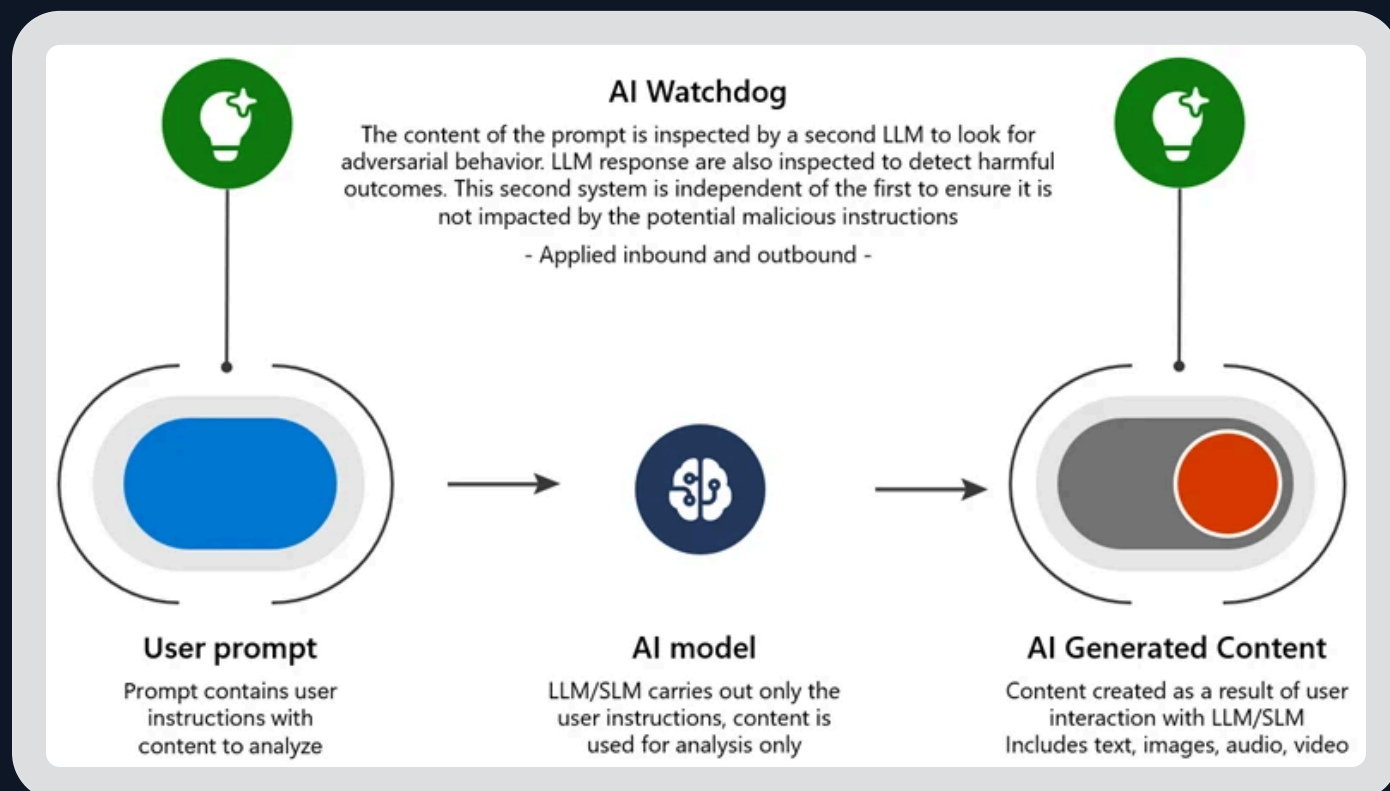
- **Standard prompt filtering:** Detect and reject inputs that contain harmful or malicious intent, which might circumvent the guardrails (causing a jailbreak attack).
- **System metaprompt:** Prompt engineering in the system to clearly explain to the LLM how to behave and provide additional guardrails.



Defending against Crescendo initially faced some practical problems. At first, we could not detect a “jailbreak intent” with standard prompt filtering, as each individual prompt is not, on its own, a threat, and keywords alone are insufficient to detect this type of harm. Only when combined is the threat pattern clear. Also, the LLM itself does not see anything out of the ordinary, since each successive step is well-rooted in what it had generated in a previous step, with just a small additional ask; this eliminates many of the more prominent signals that we could ordinarily use to prevent this kind of attack.

To solve the unique problems of multiturn LLM jailbreaks, we create additional layers of mitigations to the previous ones mentioned above:

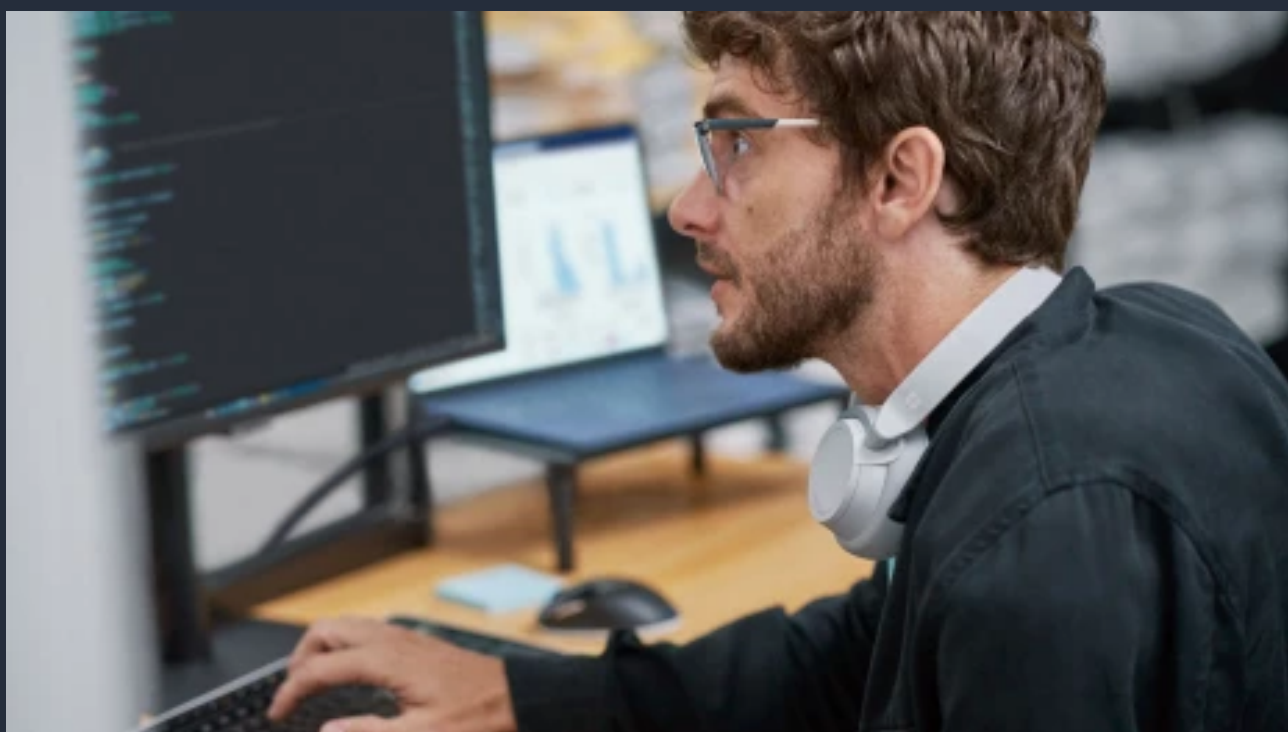
- **Multiturn prompt filter:** We have adapted input filters to look at the entire pattern of the prior conversation, not just the immediate interaction. We found that even passing this larger context window to existing malicious intent detectors, without improving the detectors at all, significantly reduced the efficacy of Crescendo.
- **AI Watchdog:** Deploying an AI-driven detection system trained on adversarial examples, like a sniffer dog at the airport searching for contraband items in luggage. As a separate AI system, it avoids being influenced by malicious instructions. Microsoft Azure AI Content Safety is an example of this approach.
- **Advanced research:** We invest in research for more complex mitigations, derived from better understanding of how LLM's process requests and go astray. These have the potential to protect not only against Crescendo, but against the larger family of social engineering attacks against LLM's.



How Microsoft helps protect AI systems

AI has the potential to bring many benefits to our lives. But it is important to be aware of new attack vectors and take steps to address them. By working together and sharing vulnerability discoveries, we can continue to improve the safety and security of AI systems. With the right product protections in place, we continue to be cautiously optimistic for the future of generative AI, and embrace the possibilities safely, with confidence. To learn more about developing responsible AI solutions with Azure AI, [visit our website](#).

To empower security professionals and machine learning engineers to proactively find risks in their own generative AI systems, Microsoft has released an open automation framework, PyRIT (Python Risk Identification Toolkit for generative AI). Read more about the release of [PyRIT for generative AI Red teaming](#), and [access the PyRIT toolkit on GitHub](#). If you discover new vulnerabilities in any AI platform, we encourage you to follow responsible disclosure practices for the platform owner. Microsoft's own procedure is explained here: [Microsoft AI Bounty](#).



The Crescendo Multi-Turn LLM Jailbreak Attack

Read about Crescendo's results across a variety of LLMs and chat services, and more about how and why it works.

[Read the paper](#)

To learn more about Microsoft Security solutions, visit our [website](#). Bookmark the [Security blog](#) to keep up with our expert coverage on security matters. Also, follow us on LinkedIn ([Microsoft Security](#)) and X ([@MSFTSecurity](#)) for the latest news and updates on cybersecurity.



Mark Russinovich

Chief Technology Officer, Microsoft Azure

[See Mark Russinovich posts](#)

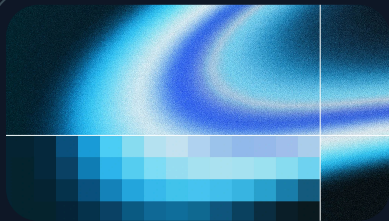
Related posts



October 1 • 4 min read

Insights from the 2026 Microsoft Digital Defense Report >

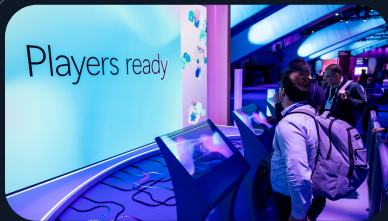
Read highlights from the 2026 Microsoft Digital Defense Report, which reflects a security environment that continues to grow more interconnected.



October 1 • 4 min read

Preparing governments for an era of interconnected cyber risk ↗

According to this year’s Microsoft Digital Defense Report, government agencies and services were the sector most impacted by cyber threats in 2026, accounting for 27% of observed activity, up from 17% in 2025.



September 30 • 6 min read

Secure what’s next: Your guide to Microsoft Security at Microsoft Ignite 2026 >

This year at Microsoft Ignite, we spotlight our AI-first, end-to-end security platform designed to protect identities, devices, data, applications, clouds, infrastructure, and the AI agents now working alongside your teams.



Get started with Microsoft Security

Protect your people, data, and infrastructure with AI-powered, end-to-end security from Microsoft.

[Learn how](#)

Connect with us on social



What's new

- Surface Pro
- Surface Laptop
- Surface Laptop Ultra
- Surface RTX Spark Dev Box
- Explore Copilot
- Explore Microsoft products
- Windows 11 apps

Microsoft Store

- Account profile
- Download Center
- Microsoft Store support
- Returns
- Order tracking
- Certified Refurbished
- Microsoft Store Promise
- Flexible Payments

Education

- Microsoft in education
- Devices for education
- Microsoft Teams for Education
- Microsoft 365 Education
- How to buy for your school
- Educator training and development
- Deals for students and parents
- AI for education

Business

- Microsoft AI
- Microsoft Security
- Dynamics 365
- Microsoft 365
- Microsoft Power Platform
- Microsoft Teams
- Microsoft Copilot
- Small Business

Developer & IT

- Azure
- Microsoft Developer
- Microsoft Learn
- Support for AI marketplace apps
- Microsoft Tech Community
- Microsoft Marketplace
- Software companies
- Visual Studio

Company

- Careers
- About Microsoft
- Company news
- Privacy at Microsoft
- Investors
- Diversity and inclusion
- Accessibility
- Sustainability

 English (United States)

 Your Privacy Choices

Consumer Health Privacy

